



De La Salle University
College of Computer Studies

Secure Web Development Case Project Checklist

Group Members

Date:

Section:

Grade:

/58

Requirement	Complete (2)	Incomplete (1)	Missing (0)
1.0 Pre-demo Requirements (must be created before the actual demo)			
1.1. Accounts (at least 1 per type of user)			
1.1.1. Website Administrator			
1.1.2. Product Manager			
1.1.3. Customer			
2.0 Demo Requirements			
2.1. Authentication			
2.1.1. Require authentication for all pages and resources, except those specifically intended to be public			
2.1.2. All authentication controls should fail securely			
2.1.3. Only cryptographically strong one-way salted hashes of passwords are stored			
2.1.4. Authentication failure responses should not indicate which part of the authentication data was incorrect. For example, instead of "Invalid username" or "Invalid password", just use "Invalid username and/or password" for both			
2.1.5. Enforce password complexity requirements established by policy or regulation			
2.1.6. Enforce password length requirements established by policy or regulation			
2.1.7. Password entry should be obscured on the user's screen (use of dots or asterisks on the display)			
2.1.8. Enforce account disabling after an established number of invalid login attempts (e.g., five attempts is common). The account must be disabled for a period of time sufficient to discourage brute force guessing of credentials, but not so long as to allow for a denial-of-service attack to be performed			
2.1.9. Password reset questions should support sufficiently random answers. (e.g., "favorite book" is a bad question because "The Bible" is a very common answer)			
2.1.10. Prevent password re-use			
2.1.11. Passwords should be at least one day old before they can be changed, to prevent attacks on password re-use			
2.1.12. The last use (successful or unsuccessful) of a user account should be reported to the user at their next successful login			
2.1.13. Re-authenticate users prior to performing critical operations such as password change			
2.2. Authorization/Access Control			
2.2.1. Use a single site-wide component to check access authorization			
2.2.2. Access controls should fail securely			
2.2.3. Enforce application logic flows to comply with business rules			

Requirement	Complete (2)	Incomplete (1)	Missing (0)
2.3. Data Validation			
2.3.1. All validation failures should result in input rejection. Sanitizing should not be used.			
2.3.2. Validate data range			
2.3.3. Validate data length			
2.4. Error Handling and Logging			
2.4.1. Use error handlers that do not display debugging or stack trace information			
2.4.2. Implement generic error messages and use custom error pages			
2.4.3. Logging controls should support both success and failure of specified security events			
2.4.4. Restrict access to logs to only website administrators			
2.4.5. Log all input validation failures			
2.4.6. Log all authentication attempts, especially failures			
2.4.7. Log all access control failures			
TOTAL	/58		